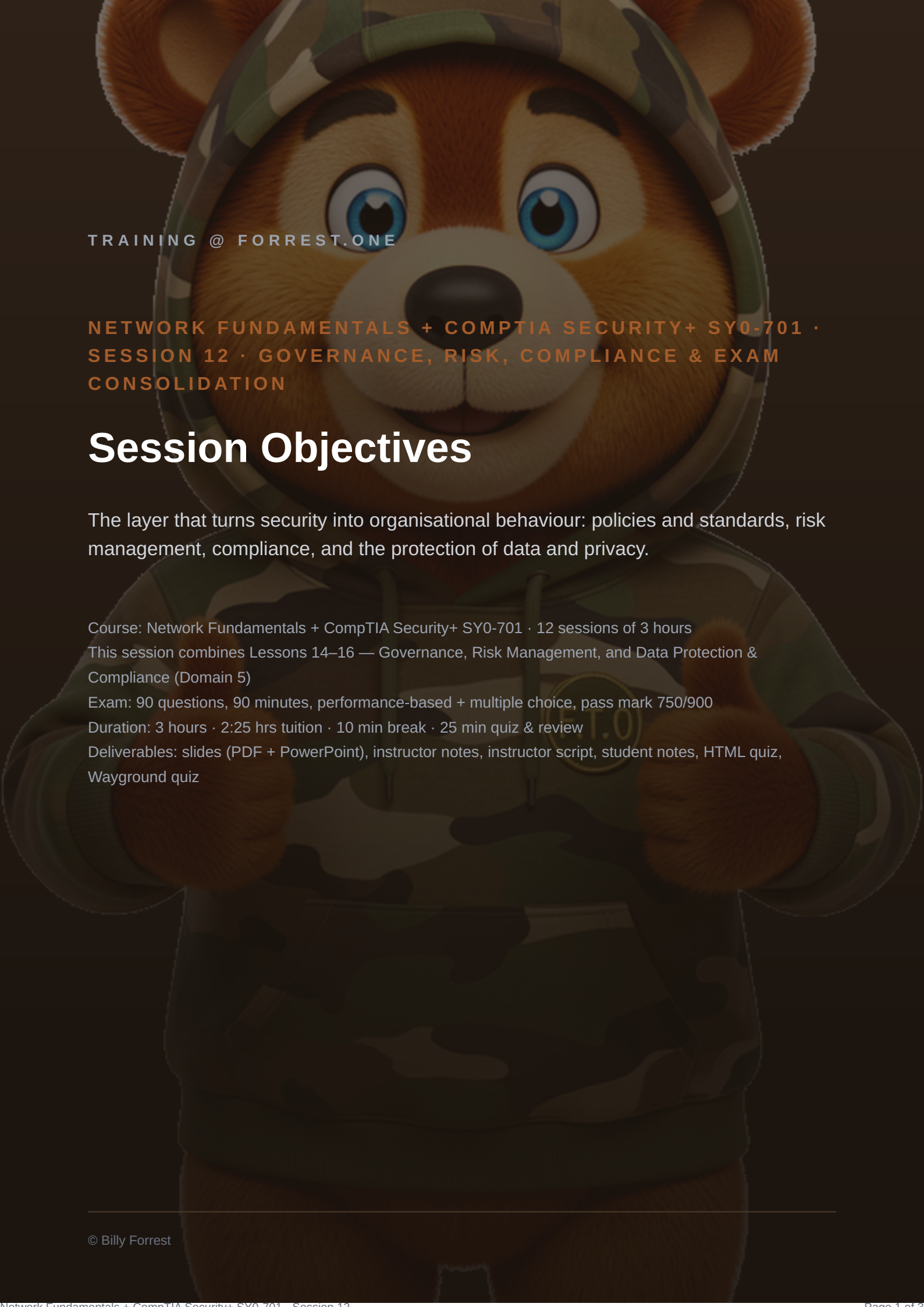




TRAINING @ FORREST.ONE

**NETWORK FUNDAMENTALS + COMPTIA SECURITY+ SY0-701 ·
SESSION 12 · GOVERNANCE, RISK, COMPLIANCE & EXAM
CONSOLIDATION**

Session Objectives

The layer that turns security into organisational behaviour: policies and standards, risk management, compliance, and the protection of data and privacy.

Course: Network Fundamentals + CompTIA Security+ SY0-701 · 12 sessions of 3 hours

This session combines Lessons 14–16 — Governance, Risk Management, and Data Protection & Compliance (Domain 5)

Exam: 90 questions, 90 minutes, performance-based + multiple choice, pass mark 750/900

Duration: 3 hours · 2:25 hrs tuition · 10 min break · 25 min quiz & review

Deliverables: slides (PDF + PowerPoint), instructor notes, instructor script, student notes, HTML quiz, Wayground quiz

Session Objectives: Governance, Risk, Compliance & Exam Consolidation

The final session combines Lessons 14, 15 and 16 of the Cyber Academy programme and maps to Domain 5 (Security Program Management and Oversight, 20% of the exam). It steps back from technical controls and turns security into an organisational discipline: governance that sets direction, risk management that spends money wisely, compliance that is proved with evidence, and an awareness programme that turns users into sensors.

Learning outcomes

By the end of the 3-hour session, candidates will be able to:

- Explain why governance comes first, and how it aligns security with business objectives.
- Describe governance structures: the security committee, reporting lines, executive oversight, authority and accountability.
- Distinguish the executive roles (CISO, security directors, the board) from the operational roles (analyst, administrator, architect).
- Explain data ownership, naming the data owner and the data custodian.
- Separate the four governance document types: policy, standard, guideline and procedure, and describe the document lifecycle.
- Explain regulatory requirements (HIPAA, PCI DSS, NERC CIP, GDPR, CCPA), contractual obligations and legal considerations.
- Identify risks using asset inventories, threat modelling and vulnerability assessments.
- Assess risk on the axes of likelihood and impact, and compare qualitative with quantitative methods.
- Calculate single loss expectancy and annualised loss expectancy from asset value, exposure factor and annual rate of occurrence.
- Maintain a risk register with ratings, owners and treatment status.
- Distinguish risk appetite from risk tolerance.
- Apply the four risk responses: avoid, transfer, mitigate and accept.
- Tailor risk reporting to technical teams, executives and the board.
- Explain how a business impact analysis drives recovery priorities and resource allocation.
- Assess, contract and monitor vendors, and define rules of engagement.
- Map compliance frameworks to the organisations they apply to, and demonstrate compliance with evidence.
- Explain the consequences of non-compliance and the duties that privacy law adds.
- Compare internal and external audits, and describe the four audit stages.

- Explain attestation (SOC 1, SOC 2, SOC 3) and penetration testing.
- Design an awareness programme, run phishing simulations, and measure whether it works.

CompTIA exam context

Item	Detail
Exam	Network Fundamentals + CompTIA Security+ SY0-701
Objective area	Domain 5, Security Program Management and Oversight (20%)
Pass mark	750 on a scale of 100 to 900
Style	Scenario questions: which document, which risk response, which compliance duty
Practical	Performance-based items may test risk and data decisions

Lessons 14–16 coverage

ID	Area	What is covered
12A	Governance	Why governance comes first; structures and accountability; executive and operational roles; the four document types; external obligations
12B	Risk Management	Identification; likelihood and impact; SLE and ALE; the register; appetite and tolerance; the four responses; reporting and BIA; vendor risk
12C	Compliance, Privacy & Assurance	Frameworks; monitoring and evidence; non-compliance and privacy; audits; attestation and penetration testing; awareness programmes
12D	Data Protection	Classification; roles; lifecycle and retention; privacy law; sovereignty

How this session maps to the exam

Every activity and quiz question is tagged with the exam objective it tests (e.g. 12.2 Risk Management). Using the session quiz to 70%+ before the exam is the fastest route to Domain 5 marks, and this session closes the five-domain map for the whole course.